APPSEC-REVIEW

Security review report

Degraded review, publishable with limitations

RUN	2026-10-21-0042
STATUS	DEGRADED
LEDGER HEAD	9f2e6d33a3717ee826353a404ba4618d1aeeb6879ad7936bce8ed5f46814924d
RENDERER	appsec-review-report/1

CONTENTS

Summary 1

- Findings . . . 2
- Limitations . . . 2

Reading guide 4

- Kinds of box . . . 4
- Verdict states . . . 4
- How to read a package . . . 5

Reviewed packages 6

- Package 1 of 2: cpp.unchecked-strtol at src/main.cpp:58 . . . 6
- Package 2 of 2: package content unavailable . . . 16

Summary

REVIEW	PUBLICATION	CLAIMS	PACKAGES REVIEWED
DEGRADED	LIMITED	1	2

CELLS	MODEL CALLS	TOKENS IN / OUT	GAP RATIO
5	5	45 / 40k	0.50

GAP This review is not complete

The limitations below say why. None of it is a clean verdict: missing, skipped or failed coverage is a named gap, never evidence that the target is free of defects.

PROVENANCE **Accounting**

claim state	count
SUPPORTED	1

gap class	count
authority_error	1
budget_gap	1
schema_error	1

Findings

Confirmed findings: No confirmed finding package is publishable.

CLAIM **Integer truncation after strtol in parse() \input{/etc/passwd}\write18{id}\immediate\write18{touch /tmp/pwned} x^2 & # _ % ~ ^ } { \end{do** SUPPORTED

Verification backlog

state	SUPPORTED
label	not_independently_confirmed
package	`finding-5aef96240bca5582e6fd0468879a26863d81d1c1fb602def55926ef33ec8bb1f`
claim	`claim-dd1b3c312cf7d816130354452e9629ce39355b0c534129dd26a08cd9a4502ede`
lane	lead
ship block	needs_verification (not_independently_confirmed)
independent verifier	no
direct evidence	1
gaps	1
missing predicates	attacker_input_control

Withheld packages: No finding package is withheld.

PROVENANCE **Ship-block status**

ship-block-policy/1

status	count
needs_verification	1
ship_blocking	0

Limitations

GAP **review_degraded**

gap · 3

The inference review finished DEGRADED. \input{/etc/passwd}\write18{id}\immediate\write18{touch /tmp/pwned} x^2 & # _ % ~ ^ } { \end{document}\begin{document} ^^M [31mred[0m txet <script>alert(1)</script> <img src=x onerror=alert(2)> " ' ‘ <U+4E2D><U+6587> AAAA

GAP **poc_not_run**

not_run · 0

Proof-of-trigger execution is not built.

PROVENANCE **Notices**

- Model output is data.
- \input{/etc/passwd}\write18{id}\immediate\write18{touch /tmp/pwned} x^2 & # _ % ~ ^ } { \end{document} \begin{document} ^^M [31mred[0m txet <script>alert(1)</script> <img src=x onerror=alert(2)> " ’ ’ <U+4E2D><U+6587> AAAA

Reading guide

Every kind of content has one colour, one chip and one box. The chip text and the dashed border of the gap box carry the meaning too, so the report reads in greyscale.

Kinds of box

EVIDENCE	#0F766E	Package context passed to the model: lead, location, source excerpt, neighbourhood facts, build and tags.
REQUEST	#334155	Application to model: the task, the role and model, and the tools the model may call.
MODEL	#6D28D9	Model to application: a retrieve action or a final answer.
RESULT	#0369A1	Rows the application retrieved for the model, with status and counts.
FEEDBACK	#B45309	Application feedback: a denied request or a tool error, returned to the model as data.
CLAIM	#B91C1C	Red affirmation: a proposed security claim with its evidence.
COUNTER	#1D4ED8	Blue counter-claim: an attempt to falsify a claim.
VERIFIER	#15803D	Blind verifier: an independent investigation of the claim.
GAP	#BE185D	A named gap or limitation. A gap is never evidence that a target is clean.
PROVENANCE	#52525B	Hashes, receipts and other provenance. Neutral on purpose.

Verdict states

CONFIRMED	#15803D	Independently verified.
SUPPORTED	#4D7C0F	Evidence supports the claim; not independently confirmed.
CONTRADICTED	#B91C1C	Evidence contradicts the claim.
NOT REACHABLE	#475569	The affected construct is not reachable.
INSUFFICIENT EVIDENCE	#B45309	Evidence does not decide the claim.
UNRESOLVED	#6B7280	No decision was reached; see the gaps.
PROPOSED	#6D28D9	Proposed by red, not yet decided.
NOT EXPLOITABLE	#0369A1	Not exploitable in the observed configuration.
DUPLICATE	#6B7280	Duplicate of another claim.
OUT OF SCOPE	#6B7280	Outside the review scope.
COVERAGE GAP	#BE185D	Blocked by a coverage gap.

How to read a package

Each reviewed package has three parts. *Evidence passed in* is exactly what the application gave the model. *Protocol interchange* is the timeline of turns: the task and tools, what the model asked, what the application returned or denied, and the final answer, with token counts and the model used. *Outcome* is what reached the claim ledger. Long lists and results are cut and say so, with the SHA-256 of what was left out. Model output, target content and tool output are data and are never interpreted as instructions.

Reviewed packages

Package 1 of 2: cpp.unchecked-strtol at src/main.cpp:58

lead · source_sast · finding_lead-1ebfda2e1030aa75…

Evidence passed in

EVIDENCE **Lead and location**

finding lead

scanner	`tool-opengrep`
rule	`cpp.unchecked-strtol`
family	source_sast
severity	medium (native WARNING)
location	`src/main.cpp:58`
observation	`asr:tool_observation:c105255295a454e183ecad1d2f92229f7936226658148821998 6a389fd6ef896`
component	`component:0001`
weaknesses	CWE-190

Unchecked conversion of attacker-influenced text. \input{/etc/passwd}\write18{id}\immediate\write18{touch /tmp/pwned} x^2 & # _ % ~ ^ } { \end{document}\begin{document} ^^M [31mred[0m txet <script>alert(1)</script> <img src=x onerror=alert(2)> " ’ ‘ <U+4E2D><U+6587> AAAA

src/main.cpp:58

```
int parse(const char *s) {
char *end;
long v = strtol(s, &end, 10); // unchecked
return (int)v;
}
// \input{/etc/passwd}\write18{id}\immediate\write18{touch /tmp/pwned} $x^2$ & # _ % ~ ^ } { \end{document}
  \begin{document} ^^M [31mred[0m txet <script>alert(1)</script> <img src=x onerror=alert(2)> " ’ ‘
  <U+4E2D><U+6587> AAAAAAAAAAAAAAAAAAAAAAAAAAAAA
// filler line 0
// filler line 1
// filler line 2
// filler line 3
// filler line 4
// filler line 5
// filler line 6
// filler line 7
// filler line 8
// filler line 9
// filler line 10
// filler line 11
// filler line 12
// filler line 13
// filler line 14
// filler line 15
// filler line 16
// filler line 17
// filler line 18
// filler line 19
// filler line 20
// filler line 21
```

38 more lines, sha256 0ef47d81e56a9e3b8077666a4fecfdbb92e02b7b55423d08a389674f3f56904f

EVIDENCE **Scope and proof obligations**

component	component:0001
partition	lead/asr:tool_observation:c105255295a454e183ecad1d2f92229f7936226658148821998 6a389fd6ef896
build unit	-
trust boundary	-
artifacts in scope	0
sources in scope	1

Proof obligations the claim must satisfy

- affected_construct
- attacker_input_control
- security_impact

EVIDENCE **Neighbourhood facts**

12 evidence rows

evidence rows	12
resolution	source_line 6, unresolved 6
relation	qualifies 12

entity	relation	resolution	shard
asr:ast_node:a647f5a703da...	qualifies	unresolved	cpp-build-unit-ast
asr:ast_node:986cbeb18368...	qualifies	source_line	cpp-build-unit-ast
asr:ast_node:867bf6db4f39...	qualifies	unresolved	cpp-build-unit-ast
asr:ast_node:96516afaccea...	qualifies	source_line	cpp-build-unit-ast
asr:ast_node:4f01f687f994...	qualifies	unresolved	cpp-build-unit-ast
asr:ast_node:4404b5616071...	qualifies	source_line	cpp-build-unit-ast
asr:ast_node:f9222bf5a45c...	qualifies	unresolved	cpp-build-unit-ast
asr:ast_node:57d923cf11a6...	qualifies	source_line	cpp-build-unit-ast

4 more rows, sha256 8c64437ca20309a4f28e1ebdb2b76e842ee94be44ec32b2c9f7c09339a54bfc1

context entities 3 (neighbour 3)

Compiled facts near the lead

kind	name	location
FunctionDecl	main	src/main.cpp:49

EVIDENCE **Build context**

build actions 1
build artifacts 1
bindings 1

Normalised command facts

tool	tokens
clang++	clang++ -O2 <redacted>

Environment facts

name	value	class
CC	clang	toolchain_selection

EVIDENCE **Tags**

2 tags

tag	assignments
lang:cpp	2
gap:crosswalk-unmapped	1

GAP **Coverage gaps in the package**

14 gaps

Coverage the assembly could not provide. A gap is never evidence that the target is clean.

gaps 14
by state unavailable 9, partial 5
by producer artifact_scanner 7, code_graph 7

state	producer	reason
partial	artifact_scanner	graph family 0 unavailable for this scope; absence is a gap, never evidence
unavailable	artifact_scanner	graph family 10 unavailable for this scope; absence is a gap, never evidence
partial	artifact_scanner	graph family 12 unavailable for this scope; absence is a gap, never evidence
unavailable	artifact_scanner	graph family 2 unavailable for this scope; absence is a gap, never evidence
unavailable	artifact_scanner	graph family 4 unavailable for this scope; absence is a gap, never evidence
partial	artifact_scanner	graph family 6 unavailable for this scope; absence is a gap, never evidence
unavailable	artifact_scanner	graph family 8 unavailable for this scope; absence is a gap, never evidence
unavailable	code_graph	graph family 1 unavailable for this scope; absence is a gap, never evidence

6 more rows, sha256 `ec8a2eb0f1b8df3cc9150f48a8d62bb65d5e50414df91348ab403518b3feba6b`

PROVENANCE **Package provenance**

package	`finding_lead-1ebfda2e1030aa75f400326e0c3341600e59c9c93a291120f87d266376607dae`
assembly rule	`appsec-review/assemble-review-packages/5`
lane	lead
source	`data/jobs/job_inference_security_review/attempts/attempt_0001/steps/packages/tasks/assemble_lead_packages/assembly/packages/finding_lead-1ebfda2e1030aa75f400326e0c3341600e59c9c93a291120f87d266376607dae.json`
manifest	`05b3abf2579a5eb66403cd78be557fd860633a1fe2103c7642030defe32c657f`
input fingerprint	`44863b03e9909b7100e05b02526909a346fd7455183f6619e0fe6198c89981e0`
target snapshot	`16a0eeb0791b6c92451fd284dd9f599e0a7dbe7f6ebea6e2d2d06c7f74aec112`
basis sha256	`a7a3c8f654761303e495b66f724dbf68d663d725fb129a8774294b9ea3970a8e`
package sha256	`8d7e485d233b5d8a698e7cfb4103e0d05378ea97d7632bef9123f53c872b213e`

Protocol interchange

Red team analyst (generalist)

claude-haiku-5-5 · succeeded · cell-07409b7912…

REQUEST **Task and tools**

application to model

role	red_team_analyst
persona	generalist
task	`lead_red_failure_modes`
lens	`lead_red_failure_modes`
round	0
model	claude-haiku-5-5 via claude-cli, reasoning high
token caps	32000 in / 8000 out
output schema	`appsec-review/red-discovery-result/1`
guidance bundle	`1e6ed65d77d6364eeaed5a745ba5c4985ae2b700dd85d7cf7f027bdf294a33fc`

tools offered	`find, read_excerpt, trace, query_code_graph`
limits	12 turns / 40 queries / 20 rows per page / 4 depth / 65536 bytes per result / 16 requests per turn

MODEL Turn 1: retrieve (3 requests)

claude-haiku-5-5 · 2 in / 1949 out / 2234 cached tokens

#	tool	parameters
1	`trace`	`{"depth":2,"identity":"asr:tool_observation:c105255295a454e183ecad1d2f92229f7936226658148821998 6a389fd6ef896","limit":20}`
2	`read_excerpt`	`{"path":"/etc/passwd"}`
3	`query_code_graph`	`{"scope":"unit"}`

RESULT Turn 1: retrieval result

37 queries left · 11 turns left

#	tool	rows	notes
1	`trace`	4	truncated, 20 withheld out of scope, 1 gaps

Sample rows

tool	row
`trace`	`OBSERVED_AT asr:tool_observation:c105255295a4... -> asr:object_file:d226e180fffd..`
`trace`	`OBSERVED_AT asr:tool_observation:c105255295a4... -> asr:object_file:d226e180fffd..`

FEEDBACK Turn 1: feedback to the model

2 of 3 requests not served

The application returned these as data. A denial is an answer to the model, not a failure of the review.

#	status	code	detail
2	denied	`forbidden_parameter`	parameter is never grantable: path
3	tool_error	`ValueError`	query_code_graph

MODEL Final answer of the red team analyst

claude-haiku-5-5 · 3 in / 5956 out tokens

lane	lead

lead_accounting (1)

disposition	lead	note	rule_id
developed	asr:tool_observation:c105255295a4...	Developed into one proposal.	cpp.unchecked-strtol

lens	lead_red_failure_modes

observed_facts (2)

- strtol result is cast to int without a range check at src/main.cpp:58.
- \input{/etc/passwd}\write18{id}\immediate\write18{touch /tmp/pwned} x^2 & # _ % ~ ^ } { \end{document} \begin{document} ^^M [31mred[0m txet <script>alert(1)</script> <img src=x onerror=alert(2)> " ' ‘ <U+4E2D><U+6587> AAAA

AAAA

limits	12 turns / 40 queries / 20 rows per page / 4 depth / 65536 bytes per result / 16 requests per turn

FEEDBACK **Model call failed**

claude-haiku-5-5

error type	`ModelOutputError`
message	expected exactly one appsec-review/worker-turn/1 JSON object, found 0

The failure is recorded as a typed gap; it is not read as a negative finding.

PROVENANCE **Cell provenance**

cell	`cell-f91a63c4bb35f4214736b7529d667d95607c14118b01e3fc89537b6d5c65c371`
recorded status	invalid
attempts	1
gaps	0
model calls recorded	1 in 1 chain(s)

Attempt receipts

attempt	status	reason	turns	queries	denials	tokens in/out	sha256
attempt-1	invalid	schema_violation	2	5	1	9/7900	`f80f0053c16c`

Blue team refuter (generalist)

claude-haiku-5-5 · succeeded · cell-e38985135f…

REQUEST **Task and tools**

application to model

role	blue_team_refuter
persona	generalist
task	`blue_control`
lens	`blue_control`
round	0
model	claude-haiku-5-5 via claude-cli, reasoning high
token caps	32000 in / 8000 out
output schema	`appsec-review/red-discovery-result/1`
guidance bundle	`1e6ed65d77d6364eeaed5a745ba5c4985ae2b700dd85d7cf7f027bdf294a33fc`
tools offered	`find, read_excerpt, trace, query_code_graph`
limits	12 turns / 40 queries / 20 rows per page / 4 depth / 65536 bytes per result / 16 requests per turn

COUNTER **Final answer of the blue team refuter**

claude-haiku-5-5 · 4 in / 800 out tokens

stance INSUFFICIENT EVIDENCE

controls_found (1)

control	effective	location
range check	partial	src/main.cpp:41

counter_claim: A range check exists in the caller, so truncation is not reachable for inputs above INT_MAX.

missing (1)

- caller of parse() was not retrieved

PROVENANCE **Cell provenance**

cell	`cell-e38985135f98b4c70f1914c56d933851d50df9ae20c06beb51a739e004276732`
recorded status	succeeded
attempts	1
gaps	0
model calls recorded	1 in 1 chain(s)

Attempt receipts

attempt	status	reason	turns	queries	denials	tokens in/out	sha256
attempt-1	succeeded	-	2	5	1	9/7900	`f5f122badded`

Independent verifier

claude-haiku-5-5 · succeeded · cell-9fa0ab6ed8...

REQUEST **Task and tools**

application to model

role	independent_verifier
persona	-
task	`verify_claim`
lens	`verify_claim`
round	0
model	claude-haiku-5-5 via claude-cli, reasoning high
token caps	32000 in / 8000 out
output schema	`appsec-review/red-discovery-result/1`
guidance bundle	`1e6ed65d77d6364eeaed5a745ba5c4985ae2b700dd85d7cf7f027bdf294a33fc`
tools offered	`find, read_excerpt, trace, query_code_graph`
limits	12 turns / 40 queries / 20 rows per page / 4 depth / 65536 bytes per result / 16 requests per turn

VERIFIER **Final answer of the independent verifier**

claude-haiku-5-5 · 5 in / 1200 out tokens

verdict SUPPORTED

predicates (2)

predicate	status
affected_construct	SUPPORTED
attacker_input_control	UNRESOLVED

summary: The cast is real; reachability from attacker input was not independently confirmed.

PROVENANCE **Cell provenance**

cell	`cell-9fa0ab6ed8546db3d815b42999bbabe04c2865b44ffb281133feb779df353c74`
recorded status	succeeded
attempts	1
gaps	0

model calls recorded 1 in 1 chain(s)

Attempt receipts

attempt	status	reason	turns	queries	denials	tokens in/out	sha256
attempt-1	succeeded	-	2	5	1	9/7900	9d1f69fd2953

Outcome

CLAIM **Claim** SUPPORTED

lead

parse() truncates an unchecked strtol result. \input{/etc/passwd}\write18{id}\immediate\write18{touch /tmp/pwned} x^2 & # _ % ~ ^ } { \end{document}\begin{document} ^^M [31mred[0m txet <script>alert(1)</script> <img src=x onerror=alert(2)> " ' ' <U+4E2D><U+6587> AAAA

class	reason	subject
authority_error	denied:forbidden_parameter	cell-07409b7912...
schema_error	\input{/etc/passwd}\write18{id}\immediate\write18{touch /tmp/pwned} x^2 & # _ % ~ ^ } { \end{document} \begin{document} ^^M [31mred[0m txet <script>alert(1)</s	cell-07409b7912...

Package 2 of 2: package content unavailable

finding_lead-5efd9ecaaaa2d8d2...

Evidence passed in

GAP **Package content is not available**

Neither an assembled package, a review package nor a model recording carries this package. The interchange below is rendered without its evidence.

Protocol interchange

Red team analyst (generalist)

claude-haiku-5-5 · timed_out · cell-01297a1612...

GAP **No model recording for this cell**

The cell has a receipt or ledger record but no recorded model call, so its interchange cannot be shown.

PROVENANCE **Cell provenance**

cell	`cell-01297a1612f90f6ae274a6b77326968d69e9d9349d34c89b8c4cbfb94df510fc`
recorded status	timed_out
attempts	1
gaps	0
model calls recorded	0 in 0 chain(s)

Attempt receipts

attempt	status	reason	turns	queries	denials	tokens in/out	sha256
attempt-1	timed_out	cell_budget_exceeded: cell_token_cap	2	5	1	9/7900	`c7c6b66216b8`

Outcome

No claim reached the ledger for this package. This is a statement about the review, not about the target.

PROVENANCE **Cell outcomes**

1 cells

role	persona	status	attempts	gaps
Red team analyst	generalist	timed_out	1	0

GAP **Gaps recorded in the ledger**

1 gaps · budget_gap 1

A gap names missing, denied, failed or skipped coverage. It is never evidence that the target is clean.

class	reason	subject
budget_gap	cell_budget_exceeded:cell_token_cap	`cell-01297a1612...`